

StarRocks 4.1.7

Экспертное заключение по результатам аудита безопасности СУБД StarRocks 4.1.7

Статус документа: черновик (draft) для рассмотрения владельцем риска КБ.

Объект	StarRocks (open source), тег `4.1.7`, commit `b81ff9cc465a5f2e5e53104d87a59b349808abd9` от 2026-10-22
Архитектуры	shared-nothing (исследована статически и на стенде), shared-data (статически, частично)
Основание	корпоративный стандарт КБ `db_dec.docx`, требования 2.1–5.6
Метод	анализ исходного кода + динамическая проверка на `starrocks/allin1-ubuntu:4.1.7`
Дата	2026-10-29
Исполнитель	[ФИО, подразделение]

1. Вердикт

StarRocks 4.1.7 **в конфигурации по умолчанию стандарту не соответствует**. После применения рекомендованного профиля настроек (раздел 5) и внешних компенсирующих мер продукт может эксплуатироваться **только как принятый риск КБ** по п. 2.1 стандарта. Полное соответствие ключевому требованию 4.5 (защита прикладных данных от администраторов СУБД) в текущей архитектуре **технически недостижимо** — риск минимизируется, но не устраняется.

По 76 проверяемым критериям: соответствует — 12, соответствует при условиях — 15, не соответствует — 17, не поддерживается — 11, не подтверждено — 5, требует эксплуатационной проверки — 16.

Для зон PCI DSS и АС финансовых услуг без исправлений вендора соответствие **не достигается** (см. раздел 4).

2. Ключевые нарушения

Критические:

- **F-01.** Встроенная роль `db_admin` имеет чтение и выгрузку всех прикладных данных; роль неизменяема. *(4.5)*
- **F-03.** Выполнение произвольного кода в процессе FE (`ADMIN EXECUTE ON FRONTEND`, Groovy) включено по умолчанию и доступно обладателю привилегии OPERATE, в т.ч. роли `security_admin`. *(4.5, 4.1)*

Высокие:

- **F-02.** `user_admin` выдаёт себе любые права и действует от имени любого пользователя. *(4.5)*
- **F-04.** Встроенная УЗ `root`: пустой пароль по умолчанию, неудаляема, обходит Ranger. *(4.2, 4.5)*
- **F-05.** Нет парольной политики (длина, срок) и блокировки учётных записей. *(4.8, 4.2)*
- **F-06.** Административные HTTP-эндпоинты BE (изменение конфигурации, просмотр журналов) по умолчанию доступны без аутентификации и без записи в аудит. *(4.3, 5.1)*
- **F-07.** Штатный аудит неполон: вход и неуспешный вход по умолчанию не регистрируются, выход не регистрируется никогда, отсутствует атрибут «приложение». *(5.1, 5.2)*
- **F-09.** Межузловые каналы (Thrift FE↔BE, репликация BDB JE) не поддерживают TLS; узлы не аутентифицируют друг друга. Авторизация выполняется только на FE. *(2.4, 4.3)*
- **F-11.** Привилегия SECURITY (у `db_admin`, `security_admin`) позволяет управлять источником аутентификации; LDAP по умолчанию без шифрования. *(4.3, 4.5)*

Средние: F-08 (анонимные метаданные FE), F-10 (TLS клиента не принудителен), F-12 (защита журналов зависит от ОС), F-14 (собственная роль «DBA без данных» реализуема по конфиденциальности, но остаются утечки метаданных и небезопасный дефолт `enable_udf=true` в образе).

3. Что устраняется, а что нет

Устраняется настройкой (проверено на стенде):

- обязательный TLS клиентских подключений (с исключением для localhost);
- аутентификация HTTP-эндпоинтов FE и BE, блокировка анонимного изменения конфигурации;
- отключение исполнения Groovy-скриптов;
- регистрация входов и неуспешных попыток (модуль `connection`);
- замена встроенного `db_admin` собственной ролью без доступа к данным.

Не устраняется настройкой продукта (неустранимые ограничения архитектуры):

- доступ встроенных `root`, `db_admin`, `user_admin` к прикладным данным (4.5);
- отсутствие парольной политики и блокировки для встроенной аутентификации (4.8, 5.1);
- отсутствие TLS и взаимной аутентификации узлов на Thrift и BDB JE (2.4);
- отсутствие события выхода пользователя и атрибута «приложение» в аудите (5.1, 5.2).

Эти пункты закрываются только внешними компенсирующими мерами (PAM, DAM, сетевая сегментация и шифрование инфраструктурой, внешняя аутентификация СУДИР/LDAP) или исправлениями на стороне вендора.

4. Вывод по защите данных от администраторов (приоритет 1)

Инвариант «администратор выполняет администрирование СУБД, но не получает содержимое прикладных данных» в StarRocks 4.1.7 **не обеспечивается** для встроенных ролей `root`, `db_admin`, `user_admin` и (до отключения Groovy) `security_admin`. Это подтверждено на стенде. Собственная роль «DBA без данных» закрывает прямое и косвенное чтение по всем 12 проверенным путям, но сохраняет утечки метаданных и контроль над целостностью данных через операции изменения схемы.

Требование 4.5 следует оформить как риск КБ по п. 2.1 (типовой риск — доступ с повышенными привилегиями) с мероприятиями по минимизации и принятием владельцем АС/ФП или владельцем инфраструктурного продукта.

5. Условия допустимости эксплуатации

Эксплуатация StarRocks 4.1.7 в корпоративной среде допустима при одновременном выполнении условий:

1. применён профиль безопасной конфигурации (`final_report.md`, §11.2) и проверен тестами (`test_plan.md`);

2. встроенные административные роли не выдаются людям; `root` — только аварийный доступ (break-glass) через PAM;
3. кластер размещён в изолированном сетевом сегменте с шифрованием межузлового трафика средствами инфраструктуры;
4. все привилегированные учётные записи работают через PAM с записью сессий; установлен агент DAM;
5. пользователи аутентифицируются через СУДИР/LDAP (ldaps), встроенные пароли не используются;
6. журнал аудита в реальном времени доставляется в ПКБ, настроены корреляционные правила на действия администраторов (GRANT себе, EXECUTE AS, ADMIN EXECUTE, изменение источника аутентификации, BACKUP/EXPORT);
7. риски по F-01, F-03, F-05, F-09 заведены и приняты в установленном порядке.

Без исправлений вендора по F-01, F-05, F-07, F-09 размещение данных платёжных карт и данных АС для предоставления финансовых услуг **не рекомендуется**.

6. Ограничения заключения

Заключение основано на анализе исходного кода версии 4.1.7 и проверках на изолированном стенде. Эксплуатация уязвимостей не выполнялась; ряд направлений (внешние каталоги, JWT/OAuth2, shared-data, шифрование данных «на покое», сторонние зависимости) исследован частично или не исследован (`coverage.md`). Нормативные документы /4/–/12/ стандарта не предоставлены — зависимые от них критерии оценены только в не зависящей от их содержания части. Процент покрытия не следует трактовать как уровень защищённости продукта.

Приложения: `final_report.md`, `requirements_matrix.md`, `findings.md`, `test_plan.md`, `evidence/`.

Подготовил: _____ [ФИО, должность, дата]

Рассмотрел (владелец риска КБ): _____ [ФИО, должность, дата]